

CYBER SECURITY ENGINEER

FULL MOCK E-TEST

Test Type:	Professional Assessment
Total Questions:	75 Multiple Choice Questions
Time Allowed:	120 Minutes (2 Hours)
Passing Score:	70% (53 correct answers)
Difficulty Level:	Intermediate to Advanced
Question Format:	Single Best Answer

INSTRUCTIONS TO CANDIDATES:

1. This test contains 75 multiple-choice questions covering all aspects of cybersecurity
2. Each question has FOUR options (A, B, C, D) - select the BEST answer
3. Time management is crucial - approximately 96 seconds per question
4. All questions carry equal marks - no negative marking
5. Answer key is provided at the end of this document
6. Do not use any reference materials during the test

Test Coverage:

Network Security • Application Security • Cryptography • Cloud Security
Incident Response • Threat Intelligence • Identity & Access Management
Security Architecture • Compliance & Risk • Secure Development

SECTION 1: NETWORK SECURITY (Q1-12)

1. Which layer of the OSI model does a stateful firewall primarily operate at?

- A) Layer 2 (Data Link)
- B) Layer 3 (Network)
- ☒ C) Layer 4 (Transport)
- D) Layer 7 (Application)

2. What is the primary purpose of implementing port security on network switches?

- A) Increase bandwidth
- ☒ B) Prevent unauthorized devices from connecting
- C) Enable QoS
- D) Configure VLANs

3. In an IPsec VPN, which protocol provides data confidentiality?

- A) AH (Authentication Header)
- ☒ B) ESP (Encapsulating Security Payload)
- C) IKE (Internet Key Exchange)
- D) ISAKMP

4. What does an IDS do when it detects suspicious activity?

- A) Blocks the traffic automatically
- ☒ B) Alerts administrators without blocking
- C) Resets the connection
- D) Quarantines the host

5. Which attack technique uses ICMP packets larger than the maximum allowed size?

- A) Smurf attack
- ☒ B) Ping of Death
- C) SYN flood
- D) DNS amplification

6. What is the primary difference between a network-based IDS and host-based IDS?

- A) Detection methods
- ☒ B) Deployment location and scope of monitoring
- C) Alert mechanisms
- D) Cost

7. Which protocol should be used to securely transfer files over an untrusted network?

- A) FTP
- B) TFTP
- ☒ C) SFTP or SCP
- D) HTTP

8. What does BGP hijacking accomplish?

- A) Steals bandwidth
- ☒ B) Redirects Internet traffic through malicious routes
- C) Increases routing efficiency
- D) Provides load balancing

9. In 802.1X authentication, which component acts as the intermediary between the supplicant and authentication server?

- A) Radius server
- ☒ B) Authenticator
- C) Access point
- D) Certificate authority

10. What is the purpose of network segmentation in security architecture?

- A) Increase network speed
- ☒ B) Limit blast radius and contain breaches
- C) Reduce hardware costs
- D) Simplify management

11. Which vulnerability scanning technique involves authenticated access to systems?

- A) Non-credentialed scanning
- ☒ B) Credentialed scanning
- C) Port scanning
- D) Passive scanning

12. What does a SIEM correlation rule based on 'failed login followed by successful login' likely detect?

- A) Normal user behavior
- ☒ B) Potential brute force attack success
- C) System malfunction
- D) Network congestion

SECTION 2: APPLICATION SECURITY (Q13-24)

13. Which OWASP Top 10 vulnerability involves untrusted data being executed as code?

- A) Broken Authentication
- ☒ B) Injection
- C) XSS
- D) CSRF

14. What is the most effective defense against SQL injection attacks?

- A) Input length restrictions
- ☒ B) Parameterized queries/prepared statements
- C) Web application firewall
- D) Encryption

15. Which HTTP header prevents browsers from MIME-sniffing a response away from the declared content-type?

- A) X-Frame-Options
- ☒ B) X-Content-Type-Options
- C) Content-Security-Policy
- D) Strict-Transport-Security

16. In a reflected XSS attack, where does the malicious script originate?

- A) Database
- ☒ B) User's request (URL or form)
- C) Web server configuration
- D) Third-party API

17. What does SAST (Static Application Security Testing) analyze?

- A) Running application behavior
- ☒ B) Source code without execution
- C) Network traffic
- D) User interactions

18. Which vulnerability allows an attacker to access files outside the web root directory?

- A) SQL injection
- B) CSRF
- ☒ C) Path traversal/directory traversal
- D) XXE

19. What is the primary purpose of implementing Content Security Policy (CSP)?

- A) Prevent SQL injection
- ☒ B) Mitigate XSS attacks by controlling resource sources
- C) Enforce HTTPS
- D) Prevent CSRF

20. In secure coding, what does 'input validation' primarily prevent?

- A) Performance issues
- ☒ B) Injection attacks and data corruption
- C) Memory leaks
- D) Race conditions

21. Which authentication mechanism is vulnerable to replay attacks without additional protections?

- ☒ A) Basic authentication over HTTP
- ☐ B) TOTP-based MFA
- ☐ C) Certificate-based authentication
- ☐ D) Kerberos

22. What does the SameSite cookie attribute help prevent?

- ☐ A) SQL injection
- ☒ B) CSRF attacks
- ☐ C) XSS attacks
- ☐ D) Session fixation

23. In API security, what does rate limiting primarily protect against?

- ☐ A) SQL injection
- ☒ B) Abuse, scraping, and DoS attacks
- ☐ C) Man-in-the-middle attacks
- ☐ D) XSS

24. Which OWASP vulnerability involves exposing sensitive data due to improper access controls?

- ☐ A) Broken Authentication
- ☒ B) Broken Access Control
- ☐ C) Security Misconfiguration
- ☐ D) Sensitive Data Exposure

SECTION 3: CRYPTOGRAPHY (Q25-34)

25. Which encryption algorithm is asymmetric?

- A) AES
- B) DES
- ☒ C) RSA
- D) Blowfish

26. What is the primary purpose of a cryptographic hash function?

- A) Encrypt data
- ☒ B) Generate fixed-size output for integrity verification
- C) Compress data
- D) Generate random numbers

27. Which hash algorithm is part of the SHA-2 family and commonly used today?

- A) MD5
- B) SHA-1
- ☒ C) SHA-256
- D) NTLM

28. In PKI, what is the purpose of a Certificate Revocation List (CRL)?

- A) Store private keys
- ☒ B) List certificates that are no longer valid
- C) Generate new certificates
- D) Encrypt communications

29. What does Perfect Forward Secrecy (PFS) ensure in TLS?

- A) Faster encryption
- ☒ B) Session keys cannot be compromised even if long-term keys are
- C) Stronger encryption algorithms
- D) Automatic key rotation

30. Which attack attempts to find the original message from its hash value?

- A) Birthday attack
- B) Collision attack
- ☒ C) Preimage attack
- D) Rainbow table attack

31. What is the key size of RSA-2048?

- A) 1024 bits
- ☒ B) 2048 bits
- C) 4096 bits
- D) 256 bits

32. Which cryptographic primitive provides non-repudiation?

- A) Symmetric encryption
- B) Hash functions
- ☒ C) Digital signatures
- D) Random number generators

33. What is the primary advantage of elliptic curve cryptography (ECC) over RSA?

- A) Easier implementation
- ☒ B) Smaller key sizes for equivalent security levels
- C) Faster decryption
- D) Better browser support

34. In TLS 1.3, which outdated feature was removed to improve security?

- A) Certificate validation
- ☒ B) Static RSA key exchange
- C) AES encryption
- D) SHA-256 hashing

SECTION 4: INCIDENT RESPONSE & FORENSICS (Q35-42)

35. What is the correct order of phases in the incident response lifecycle (NIST)?

- A) Containment, Detection, Preparation, Recovery
- B) Preparation, Detection/Analysis, Containment/Eradication/Recovery, Post-Incident**
- C) Detection, Preparation, Recovery, Analysis
- D) Analysis, Containment, Recovery, Documentation

36. During digital forensics, what is the purpose of creating a forensic image?

- A) Compress evidence
- B) Preserve original evidence and create bit-for-bit copy**
- C) Encrypt evidence
- D) Delete temporary files

37. Which volatile data should be collected FIRST during incident response?

- A) Hard disk contents
- B) CPU registers and RAM contents**
- C) Log files
- D) Network configuration

38. What does the term 'chain of custody' refer to in digital forensics?

- A) Network path of attack
- B) Documented handling of evidence from collection to court**
- C) Malware propagation path
- D) Administrative access chain

39. In malware analysis, what is the difference between static and dynamic analysis?

- A) Static analyzes code without execution; dynamic observes runtime behavior**
- B) Static is automated; dynamic is manual
- C) Static is faster; dynamic is slower
- D) No significant difference

40. What is an Indicator of Compromise (IoC)?

- A) Vulnerability identifier
- B) Evidence that a system has been breached**
- C) Compliance requirement
- D) Security control

41. During containment, what is the difference between isolation and segmentation?

- A) No difference
- ☒ B) Isolation completely disconnects; segmentation restricts network access
- C) Isolation is temporary; segmentation is permanent
- D) Isolation is for servers; segmentation is for endpoints

42. What should be the first step when ransomware is detected on a system?

- A) Pay the ransom
- B) Reboot the system
- ☒ C) Isolate the infected system from network
- D) Delete all files

SECTION 5: CLOUD SECURITY (Q43-50)

43. In the cloud shared responsibility model, who is responsible for data classification?

- A) Cloud provider
- B) Customer**
- C) Third-party auditor
- D) Both provider and customer

44. Which cloud service model gives customers the MOST control over the infrastructure?

- A) SaaS
- B) PaaS
- C) IaaS**
- D) FaaS

45. What is a CASB (Cloud Access Security Broker)?

- A) Cloud backup service
- B) Security enforcement point between users and cloud services**
- C) Cloud storage provider
- D) Virtual firewall

46. Which attack exploits misconfigured S3 buckets?

- A) SQL injection
- B) Public data exposure due to improper access controls**
- C) DDoS
- D) Man-in-the-middle

47. What does 'infrastructure as code' (IaC) help prevent in cloud environments?

- A) DDoS attacks
- B) Configuration drift and manual errors**
- C) SQL injection
- D) Phishing

48. In serverless computing, what is the primary security concern?

- A) Physical security
- B) Function-level vulnerabilities and event injection**
- C) Network firewall rules
- D) BIOS security

49. Which cloud security tool helps discover shadow IT?

- A) Firewall
- B) CASB with discovery capabilities**
- C) IDS
- D) Antivirus

50. What is the primary purpose of cloud workload protection platforms (CWPP)?

- A) Email filtering
- ☒ B) Protect VMs, containers, and serverless workloads
- C) DNS security
- D) Identity management

SECTION 6: IDENTITY & ACCESS MANAGEMENT (Q51-57)

51. Which access control model bases permissions on user roles?

- A) DAC (Discretionary Access Control)
- B) MAC (Mandatory Access Control)
- ☒ C) RBAC (Role-Based Access Control)
- D) ABAC (Attribute-Based Access Control)

52. What does OAuth 2.0 primarily provide?

- A) User authentication
- ☒ B) Authorization delegation without sharing credentials
- C) Password encryption
- D) User provisioning

53. In multi-factor authentication, which factor is a biometric?

- A) Password
- B) Security token
- ☒ C) Fingerprint
- D) PIN

54. What is the primary purpose of privileged access management (PAM)?

- A) Monitor network traffic
- ☒ B) Control and audit access to critical systems and administrative accounts
- C) Manage regular user accounts
- D) Encrypt data

55. Which protocol is commonly used for federated identity management?

- A) SMTP
- ☒ B) SAML
- C) FTP
- D) SNMP

56. What does 'just-in-time' (JIT) access provide?

- A) Permanent access rights
- ☒ B) Temporary elevated privileges for specific time periods
- C) Faster login
- D) Multi-factor authentication

57. In the context of identity lifecycle management, what is 'deprovisioning'?

- A) Creating new user accounts
- ☒ B) Revoking access when users leave or change roles
- C) Password reset
- D) Account lockout

SECTION 7: THREAT INTELLIGENCE & DETECTION (Q58-63)

58. What is the Cyber Kill Chain primarily used for?

- A) Password management
- ☒ B) Understanding attacker methodology and defensive opportunities
- C) Network design
- D) Compliance auditing

59. Which framework describes adversary tactics and techniques?

- A) NIST CSF
- B) ISO 27001
- ☒ C) MITRE ATT&CK;
- D) CIS Controls

60. What is the difference between threat intelligence and threat data?

- A) No difference
- ☒ B) Intelligence is analyzed and contextualized data
- C) Data is more expensive
- D) Intelligence is automated

61. Which type of indicator is an IP address or domain used by attackers?

- A) Behavioral indicator
- B) Network indicator**
- C) Host indicator
- D) Compliance indicator

62. What does TTP stand for in threat intelligence?

- A) Threat Transfer Protocol
- B) Tactics, Techniques, and Procedures**
- C) Technical Testing Platform
- D) Target Threat Profile

63. In threat hunting, what is a hypothesis-driven approach?

- A) Random log searching
- B) Starting with a threat assumption and searching for evidence**
- C) Automated scanning
- D) Compliance checking

SECTION 8: COMPLIANCE & RISK MANAGEMENT (Q64-69)

64. What does GDPR require for data breach notifications?

- A) Notification within 30 days
- ☒ B) Notification within 72 hours to supervisory authority
- C) Notification within 1 week
- D) No specific timeframe

65. Which standard specifically addresses payment card data security?

- A) HIPAA
- B) SOX
- ☒ C) PCI DSS
- D) FISMA

66. In risk management, what is 'risk acceptance'?

- A) Eliminating all risks
- ☒ B) Acknowledging risk and choosing not to mitigate
- C) Transferring risk to others
- D) Ignoring risk

67. What does RPO (Recovery Point Objective) define?

- A) Maximum acceptable downtime
- ☒ B) Maximum acceptable data loss measured in time
- C) Backup frequency
- D) Recovery cost

68. Which framework provides a risk-based approach to cybersecurity?

- ☒ A) NIST Cybersecurity Framework
- B) OWASP Top 10
- C) SANS Top 25
- D) CVE

69. What is the purpose of a Security Impact Assessment (SIA)?

- A) Test system performance
- ☒ B) Evaluate security implications of new systems or changes
- C) Conduct penetration testing
- D) Train employees

SECTION 9: SECURITY ARCHITECTURE & ENGINEERING (Q70-75)

70. What does 'defense in depth' strategy involve?

- A) Using only one strong security control
- ☒ B) Layering multiple security controls
- C) Focusing only on perimeter security
- D) Relying on encryption alone

71. In Zero Trust architecture, what is the core principle?

- A) Trust all internal network traffic
- B) Never trust, always verify**
- C) Trust based on network location
- D) Trust after initial authentication

72. What is micro-segmentation in network architecture?

- A) Creating VLANs
- B) Granular security controls at the workload level**
- C) Physical network separation
- D) DNS filtering

73. Which security principle states that security mechanisms should fail to a safe state?

- A) Fail open
- B) Fail secure/fail safe**
- C) Fail fast
- D) Fail forward

74. What is the primary purpose of security orchestration?

- A) Manual incident response
- B) Coordinate and automate security tools and processes**
- C) Log collection
- D) Firewall configuration

75. In secure system design, what does 'least privilege' mean?

- A) Give administrators full access
- B) Grant minimum access necessary for job function**
- C) Deny all access by default
- D) Share passwords among teams

ANSWER KEY

Q#	Ans	Q#	Ans	Q#	Ans	Q#	Ans	Q#	Ans
1	C	2	B	3	B	4	B	5	B
6	B	7	C	8	B	9	B	10	B
11	B	12	B	13	B	14	B	15	B
16	B	17	B	18	C	19	B	20	B
21	A	22	B	23	B	24	B	25	C
26	B	27	C	28	B	29	B	30	C
31	B	32	C	33	B	34	B	35	B
36	B	37	B	38	B	39	A	40	B
41	B	42	C	43	B	44	C	45	B
46	B	47	B	48	B	49	B	50	B
51	C	52	B	53	C	54	B	55	B
56	B	57	B	58	B	59	C	60	B
61	B	62	B	63	B	64	B	65	C
66	B	67	B	68	A	69	B	70	B
71	B	72	B	73	B	74	B	75	B

SCORE INTERPRETATION

Score Range	Percentage	Grade	Assessment
68-75	91-100%	Excellent	Expert-level knowledge
60-67	80-90%	Very Good	Strong cybersecurity skills
53-59	70-79%	Good (Pass)	Competent for the role
45-52	60-69%	Fair	Needs improvement
Below 45	Below 60%	Needs Study	Significant gaps in knowledge

DOMAIN BREAKDOWN

Network Security: Questions 1-12 (16%)

Application Security: Questions 13-24 (16%)

Cryptography: Questions 25-34 (13%)

Incident Response & Forensics: Questions 35-42 (11%)

Cloud Security: Questions 43-50 (11%)

Identity & Access Management: Questions 51-57 (9%)

Threat Intelligence & Detection: Questions 58-63 (8%)

Compliance & Risk Management: Questions 64-69 (8%)

Security Architecture & Engineering: Questions 70-75 (8%)